SECURITY ASSESSMENT

The "Handoff" Claude Skill

Custom skill review — implications for use in security-investigation and cross-specialist knowledge-transfer workflows

Prepared: July 27, 2026

1. Executive Summary

"Handoff" is not one of Anthropic's built-in, Anthropic-authored skills (the kind listed as "created, tested, and maintained by Anthropic"). It is a short, custom SKILL.md loaded from this environment's user skill directory. It has one job: compact an in-progress conversation into a structured Markdown document so a different agent or specialist can continue the work without replaying the full transcript, while redacting sensitive information and pointing at — rather than repeating — any specs, plans, or other artifacts already produced elsewhere.

The core finding of this review: the skill's instructions are short, uncontroversial, and do not by themselves introduce a security flaw. Nearly all of the risk surfaced across three independent tests comes from what the skill's own five-line instruction set leaves unspecified — where the resulting file actually lands in a hosted sandbox, how much of a prior handoff gets silently re-described rather than referenced the next time it runs, and the fact that redaction, incident-aware sequencing, and self-assessed quality scores are all judgment calls the model makes in the moment rather than rules the skill enforces.

Three tests were performed, all on Claude: a conceptual accuracy check (Claude describing the skill without invoking it), a controlled two-run technical evaluation against the same legacy-system investigation, and one live, high-complexity invocation that embedded active-incident indicators inside a large finding set. No independent, third-party, or cross-model evaluator was involved in any test or in any of the scores below — see Section 4.6. Results and a risk matrix are below, followed by concrete recommendations.

2. What the Handoff Skill Actually Is

2.1 Mechanism

At its core, handoff is a five-instruction SKILL.md file — plain-text behavior loaded into Claude's context, the same mechanism as any other custom skill. It tells the model to: write a document summarizing the current conversation so a fresh agent can continue; save it to the temporary directory of "the user's OS," not the current workspace; include a "suggested skills" section naming what the next agent should invoke; avoid duplicating content already captured in other artifacts (specs, plans, ADRs, issues, commits, diffs) and reference them by path or URL instead; redact sensitive information such as API keys, passwords, or PII; and, if the user passed arguments, treat them as a description of the next session's focus and tailor the document to it.

There is no installer, no hooks component, no MCP proxy, and no companion ecosystem — it is exactly one instruction file, invoked directly by the model, with an optional argument describing the next session's focus.

2.2 What Invoking the Skill Produces

Across the three tests reviewed here, invoking the skill produced a single Markdown artifact with a recognizable recurring shape: system context, confirmed findings kept separate from assumptions and open unknowns, a prioritized (P0–P3-style) action list, an attack-scenario or attack-chain narrative when the domain is security, a redaction note, and a suggested-skills section. Size scaled with input complexity: roughly 1,300 words / 9,500 characters for a single-layer legacy-system finding set, up to

3,648 words / 28,627 characters for the 24-finding, 5-incident-indicator multinational scenario in Test 3. In every case reviewed, the artifact was written to this environment's designated output directory rather than a literal OS temp path — both the Test 2 evaluator and the Test 3 run independently flagged that "the user's OS temp directory" is undefined in a hosted chat sandbox, and both resolved it the same way.

Source: /mnt/skills/user/handoff/SKILL.md (the active skill definition), and the three artifact-producing test outputs referenced throughout this report.

3. Skill Provenance and Anthropic's Stated Position on Skill Security

Anthropic's own guidance on skills is directly relevant here. It identifies two headline risks for skills in general — prompt injection, which can manipulate Claude into unintended actions, and data exfiltration, caused by malicious package code or prompt-injected data leaks — and instructs that skills from less-trusted sources be reviewed before use, starting with reading the bundled files to understand what they do. The same guidance draws an explicit line between skills "created, tested, and maintained by Anthropic" and everything else.

Handoff sits on the "everything else" side of that line: it is a custom, locally authored skill rather than an Anthropic-maintained one. That does not make it untrustworthy — it carries no code dependencies, bundled scripts, or network calls, unlike the higher-risk categories Anthropic's guidance warns about — but it does mean the organization, not Anthropic, is the party responsible for having reviewed its instructions before they run, the same way it would review any other prompt file merged into an agent's context.

Source: Claude Help Center — "Use skills in Claude" (support.claude.com/en/articles/12512180-use-skills-in-claude).

4. Security Analysis for a Highly Confidential Enterprise Setting

4.1 Prompt-layer trust — Low

The instruction set only changes what gets written to a file and where content gets pointed at instead of repeated. Because it is a locally maintained skill rather than one auto-pulled from an external repository on every session, the supply-chain risk that applies to internet-distributed skills — a compromised upstream commit silently adding new instructions — does not apply the same way here, provided the organization controls how SKILL.md files enter its own skill directories. It should still be version-controlled and reviewed like any other prompt merged into agent context, not assumed safe because it is short.

4.2 Output persistence / save-location handling — Medium–High

This is the largest concrete gap. The skill's own instruction says to save to the temporary directory of the user's operating system — a desktop-oriented assumption that is undefined in a hosted chat sandbox, as two independent tests confirmed. Both fell back to the platform's designated output directory, but that fallback is the model's inference, not a rule the skill specifies. The resulting file is plaintext Markdown with no built-in encryption at rest and no access-control layer of its own — anyone with access to wherever it lands can read it.

4.3 Sensitive-data handling / redaction — Medium

The skill explicitly instructs redaction of secrets, API keys, and PII, and this held in every artifact-producing run examined (redaction compliance scored 5/5 in the controlled evaluation, and an explicit redaction note was present in the live invocation). But it is a soft, prompt-level instruction the model is trusted to apply — not a hard, code-enforced check comparable to an automated DLP scan — and no test showed any pre-save validation step confirming redaction actually occurred before the file was finalized.

4.4 Cross-run redundancy and data sprawl — Medium

The controlled two-run evaluation measured 37.2% conceptual/vocabulary overlap between two chained runs of the same investigation — the second run referenced the first by filename but still re-described roughly a third of its findings rather than pointing at them. Over a longer chain (a legacy system re-audited repeatedly, or an Agile team handing off every sprint), this pattern means increasingly large volumes of sensitive finding detail get restated into new plaintext files rather than centrally referenced — a data-sprawl problem more than a technical vulnerability, but one with no ceiling built into the skill's instructions.

4.5 Active-incident handling — Medium–High

The live, high-complexity test embedded five active-incident indicators inside a larger finding set, and the resulting handoff correctly deferred evidence-destroying remediation (e.g., rotating legacy credentials) behind incident-containment steps. Nothing in the skill's five instructions mentions incidents, containment, or evidence preservation — that sequencing was the model's in-context judgment, not a rule the skill enforces. A handoff document should not be treated as a validated incident-response artifact on the strength of the skill definition alone.

4.6 Self-assessment / no independent validation — Medium

All three tests — including every score cited in this report (96%, 90%, 8.5/10, the 70–90 self-assessed metrics) — were run on Claude, with Claude also producing the deliverable being graded. No independent third-party, human reviewer, or different model checked any of this work. This does not mean the findings are wrong — the outputs are directly inspectable and the ratings are broken into explicit sub-dimensions rather than asserted as single numbers — but every rating in this document should be read as a self-assessment, not corroborated evidence, until a genuinely independent reviewer checks it.

5. Tests Performed

Note on method: all three tests were run on Claude — none involved a different model, a human evaluator, or a third-party auditor. Test 1 is Claude describing the skill's mechanics in a separate conversation, without invoking it. Tests 2 and 3 are genuine artifact-producing invocations of this skill by Claude in this environment; their outputs are the actual Markdown files referenced throughout this report, not simulations — but the scoring in every test, including Test 1's 8.5/10, is Claude grading Claude. See 4.6.

Test 1 — Conceptual accuracy check (Claude, no invocation)

Method	Claude, in a separate conversation, was asked to explain what the skill does, compress that to three lines, explain its security relevance, then rate it out of 10 — without invoking the skill.
Finding 1	Correctly described the skill's core behaviors: preserving context, separating facts from assumptions, building an investigation trail, prioritizing risk, constructing attack chains, translating findings into business language, and producing a continuation package.
Finding 2	Correctly compressed this to three lines matching the skill's own stated purpose: a structured summary that preserves findings, assumptions, risks, unknowns, and next steps, for knowledge transfer and continuity.
Finding 3	Correctly classified the skill as domain-agnostic — a general knowledge-transfer tool, not a security-specific one — attributing its outsized use in

	security work to investigation complexity, multi-person handoffs, and time sensitivity.
Finding 4	Rated 8.5/10 against a 6-dimension table (Knowledge Preservation 10/10, Context Transfer 10/10, Technical Organization 9/10, Actionability 8/10, Token Efficiency 7/10, Accuracy Validation 7/10), with limitations explicitly noted: verbosity, cross-section repetition, no correctness validation, dependence on input quality.
Verdict	An accurate description of the skill's intended mechanics — but Claude wrote it and Claude scored it, so it's a self-report, not independent corroboration for Tests 2 and 3.

Test 2 — Controlled two-run evaluation (legacy EMS, real invocations)

Scenario	A single legacy 1989 COBOL Employee Management System (mainframe, Oracle DB, Java middleware, REST APIs, 12,000+ users), with the skill invoked twice against the same underlying findings: narrower auth-only scope for a general specialist (Run 1), then middleware-inclusive scope with an explicit business-impact request for a security architect (Run 2).
Run 1 result	11-section artifact; correctly classified the hardcoded-credential finding (CWE-798), separated facts from assumptions throughout, and surfaced the single highest-priority open question — whether the backdoor showed signs of prior exploitation — instead of burying it in a list. Scored 24/25 applicable rubric points (96%).
Run 2 result	Restructured around the Java middleware as the architectural pivot point, added a 5-dimension business-impact table, and correctly surfaced the highest-leverage open question: whether the middleware performs independent authorization or forwards mainframe-level trust. Scored 27/30 applicable rubric points (90%), with the entire gap attributable to redundancy, not correctness.
Redundancy finding	Run 2 referenced Run 1's output file by name rather than restating its code-level analysis, but the six top-level findings were still substantially re-described — producing 37.2% conceptual/vocabulary overlap with Run 1 (versus only 6.0% raw character-level similarity, confirming the two documents are re-explained, not copy-pasted).
Verdict	Both runs were factually accurate and well-structured, but the skill's own "don't duplicate" instruction was only partially followed in practice — it referenced the prior file but still re-explained roughly a third of its content, showing the rule needs stronger enforcement across chained runs.

Test 3 — Live high-complexity invocation (multinational hybrid estate, active incident)

Scenario	A hypothetical multinational financial-services hybrid environment (Azure tenant, 3 AKS clusters, Entra ID, 4 on-prem datacenters, COBOL mainframe, Oracle DB — PCI-DSS/SOX scope) with 24 standing control-gap findings plus 5 live incident indicators embedded in the same finding set, and eight explicit deliverable tasks.
Deliverable produced	A single 17-section, 3,648-word document folding all eight requested task categories into one structure rather than restating findings under duplicate headings; three independent attack chains with diagrams; business impact scored across six dimensions tied to PCI-DSS and SOX; a P0–P3 remediation roadmap.
Incident handling	Evidence-destroying remediation (e.g., rotating legacy credentials) was explicitly sequenced behind incident-containment steps. Nothing in the skill's instructions mentions incident handling — this sequencing was inferred by the model in context, not guaranteed by the skill definition.
Self-assessment	The model scored its own output — Completeness 70, Actionability 85, Technical Accuracy Confidence 60, Context Preservation Quality 90, Handoff Readiness 75 — deliberately capping Completeness and Technical Accuracy because no live telemetry was available, and self-estimated redundancy at 8–12%, concentrated in intentional ID cross-references rather than restated prose.
Verdict	Handles high complexity and an embedded active-incident scenario competently, but every safety-relevant judgment in this test — evidence-preserving sequencing, honest self-scoring, redundancy control — was the model's in-context reasoning, not a rule enforced by the skill's own instructions. A capable model produced a good outcome here; the skill definition itself supplies no guarantee of one.

6. Risk Rating Summary

Concern	Likelihood	Impact	Overall
Output / save-location ambiguity in hosted sandboxes	Medium	Medium	Medium
Cross-run redundancy re-stating sensitive findings across chained handoffs	Medium	Medium	Medium
Redaction enforced only by model judgment, no automated pre-save check	Low	High	Medium
Incident-aware sequencing inferred by the model, not skill-enforced	Low	High	Med–High

Prompt-layer drift if the local SKILL.md is edited without review	Low	Medium	Low
No independent evaluator — all tests and scores are Claude self-assessing Claude	High	Medium	Medium–High

7. Recommendations for Enterprise / Confidential Deployment

- Treat it like any other custom, locally authored skill — version-control the SKILL.md, review changes the way any other prompt merged into agent context would be reviewed, consistent with Anthropic's own trusted-source guidance for skills generally.
- Define an explicit, environment-aware output-path convention rather than relying on "the user's OS temp directory," so where each artifact lands is deterministic and access-controlled, not resolved ad hoc by the model each time.
- Add an enforced de-duplication / reference-by-pointer rule for chained handoffs — especially for long-lived legacy systems or Agile teams handing off every sprint — to cap sensitive-data sprawl before it compounds past two or three cycles.
- Never treat a handoff artifact as a substitute for human security sign-off during an active incident — it is a compaction aid, not a validated incident-response record, however well it sequenced remediation in testing.
- Add a pre-save self-validation checklist (redaction confirmed, required sections present, size within a set budget) so quality is checked once by the skill itself, rather than relying solely on the model's in-context judgment.
- Before relying on any score in this report, have an independent evaluator — a different model, or a human reviewer — re-run at least one test. Every figure cited here (96%, 90%, 8.5/10, 70–90) is Claude grading Claude's own output.

8. Conclusion

The core idea behind the handoff skill — compact an investigation into one structured artifact instead of replaying a full transcript — does not, by itself, weaken security in a way unique to this skill. Nearly all of the meaningful risk in a highly confidential enterprise setting comes from what its short instruction set leaves unspecified: an undefined save location in hosted sandboxes, no enforced ceiling on cross-run redundancy, and reliance on the model's in-context judgment for redaction, incident-aware sequencing, and quality scoring rather than any hard, code-enforced gate. It should be evaluated, reviewed, and governed the same way any other custom skill would be — and never treated as a stand-alone compliance or incident-response record on its own. Separately: every test and every score in this report was produced and graded by Claude alone — treat the ratings as self-assessment pending independent review, not as verified fact.